

DOORS

Data Orchestration and On-demand Reporting System

Security Architecture and Controls

DOORS Security and Governance

Document ID	Version	Audience	Classification
DOORS-SECURITY-ARCHITECTURE-CONTROLS	1.0	Data Manager and Security Administrator	NIC INTERNAL

Document control

Field	Value
Title	Security Architecture and Controls
Owner	DOORS Product Governance
Version / status	1.0 / Approved for initial publication
Effective date	30 August 2026
Review cycle	At every material release or annually
Audience	Data Manager and Security Administrator
Authoritative source	Current DOORS release, configuration and governance records

Publication rule

Use the authenticated DOORS Documentation Hub as the source of truth. Downloaded copies may become obsolete after a release, security change or policy revision.

Security model

DOORS separates the management plane, gateway plane and distributed execution plane. Access is denied by default and granted through authenticated roles or registered API clients.

- No direct external database connectivity.
- Central approval and distributed execution.
- Explicit client-query-agent authorization.
- Auditable correlation across services.

Control catalogue

Area / symptom	Control / response
Identity and authentication	JWT for portal users; API keys for registered clients; optional MFA/VPN controls.
Authorization	Role checks, client mappings, agent scope and document eligibility.
Transport	TLS with verified certificate chains and hostname validation.
Payload protection	RSA-wrapped AES session keys and DOORS digital signatures where enabled.
Integrity	SHA-256 source/destination comparison and immutable correlation identifiers.
Audit	Execution, governance and document-download outcomes with actor and timestamps.
Resilience	Timeouts, bounded retries, streaming, size limits and sanitized failures.

Threats and mitigations

Area / symptom	Control / response
Credential disclosure	Secret storage, no embedding, rotation and revocation.
SQL injection	Approved parameterized templates/functions; arbitrary SQL prohibited.
Object reference forgery	Opaque signed references and server-side authorization.
Data exfiltration	Minimization, mappings, size limits, encryption and audit.
Path traversal	Whitelist document IDs and sanitized filenames.

Area / symptom	Control / response
Replay/automation abuse	Correlation, rate limits, expiry and bounded retries.
Insider misuse	RBAC, segregation, evidence and periodic review.

Certificate lifecycle

Record owner, purpose, fingerprint, validity and replacement window for every certificate.

- Verify fingerprints out of band.
- Rotate before expiry.
- Retain no private keys in DOORS for client response encryption.
- Revoke and investigate suspected compromise.

Review and assurance checklist

The document owner and reviewer must complete this page before approving a revision for publication.

- Technical statements match the currently deployed release and approved configuration.
- Role scope and segregation-of-duties boundaries are accurate.
- Examples contain no credentials, private keys, sensitive records or exploitable internal details.
- Endpoints, error meanings, limits and operational actions have been tested where applicable.
- Related test cases, runbooks and release notes have been updated.
- The authenticated Documentation Hub contains the approved version and supersedes downloaded copies.

Approval record

Record the document version, reviewer, approval reference and effective date in the governed release record. Do not add handwritten approval data to uncontrolled downloaded copies.